

Security

Models, Networks, Protocols

IT-Sicherheit | 11.03.2026

Gerald Dißbaur | Lecturer

A-SIT Secure Information Technology Center Austria

www.dhbw-stuttgart.de

Agenda

Introduction

Security Models

Network Security

Security Protocols

Summary

Agenda

Introduction

Security Models

Network Security

Security Protocols

Summary

INFORMATION SECURITY AS MOTIVATION CONNECTED MACHINES

In conjunction with the connection of distant computers via unprotected networks, information security is becoming increasingly important. Data should be protected against third parties, i.e., against malicious attackers.

The term “security”. Security is more or less contrary to the general term “*safety*”, which refers to the absence of errors or protection related to errors in the software

Agenda

Introduction

Security Models

Network Security

Security Protocols

Summary

WHAT IS THE PURPOSE OF SECURITY MODELS? FUNDAMENTALS IN CONJUNCTION WITH SECURITY POLICY

In security engineering, models are very often used to describe, study, or analyze a particular situation or relationship by:

- Document a security policy (*e.g., for a corporation, company, authority*)
- Support to conceptualize and design an implementation of a security policy
- Test particular security policies both for completeness and consistency
- Check and verify whether an implementation meets its specified requirements

***A security policy outlines objectives
without regard to how they will be achieved***

WHAT IS A SECURITY MODEL?

BASIC PRINCIPLES OF SECURITY MODELS

A security model itself represents a comprehensive theoretical construct, which represents the rules at a high level of abstraction. A security model requires detailed definitions and constructions. It maps the objectives of a security policy to information system terms by specifying data structures and techniques that are necessary to enforce the security policy.

2 general groups of security models

- (1) Positive „*Whitelist*“ security models
- (2) Negative „*Blacklist*“ security models

WHITELIST SECURITY MODELS

ONLY ALLOW WHAT HAS BEEN EXPLICITLY APPROVED

Positive security models are also known as so-called “*whitelist models*” or „*known good*“ models. Those models follow the principle in terms of general prohibition. That means that they forbid everything except what is explicitly permitted by the issued white list.

Selected practical scenarios

- Application whitelisting (AWL)
- Access control (*in case for only authorized and authenticated users*)
- DNS¹ whitelist
- firewall only allows particular IP addresses
- MAC²-Filter for WiFi³

¹ DNS – Domain Name System

² MAC – Media Access Control Address

³ WiFi – Wireless Fidelity

BLACKLIST SECURITY MODELS

PREVENT ONLY WHAT HAS BEEN PROHIBITED

Negative security models are also known as so-called “*blacklist models*” or “*known bad*”. Those models only prevent what has been prohibited for suspicious or malicious entities. However, that means that prohibitions always have the property that everything else is allowed. The “*Blacklist*” methodology can only detect and block known threats. It is a standard technique in terms of access control.

Selected practical scenarios

- DNS-based blackhole lists (*DNSBL*)
- Email blacklist
- IDS¹/IPS²
- Filtering special database characters (*e.g., single quotes*)

¹ IDS – Intrusion Detection System

² IPS – Intrusion Prevention System

WHICH SECURITY MODELS SHOULD WE CHOOSE?

WHITELIST VS. BLACKLIST SECURITY MODELS

5 comprehensive disadvantages of negative security models

- (1) “Blacklist” solutions compare the monitored objects only to a given list of what is known to be bad.
- (2) The “Blacklist” must be continuously updated when new threats are discovered
- (3) There is no way to detect certain attacks (*e.g., attacks with no signature, zero-days*)
- (4) In the rarest of cases we really know all the negative cases
- (5) There are very often certain variants or tricks (*e.g., encoding tricks*)

**Host-based and network based IDS/IPS
require regular signature updates
in order to detect more recently arising and identified threats**

WHICH SECURITY MODELS ARE RECOMMENDED?

WHITELIST VS. BLACKLIST SECURITY MODELS

Common recommendation

In general, a positive security model therefore offers significantly higher security and should therefore be preferred to a negative model.

Think "What do I have to allow?" (i.e., consider positive security model)

Don't think in "What do I have to prohibit?" (i.e., negative security model)

AN OVERVIEW ABOUT PARTICULAR SECURITY MODELS

11 SELECTED EXAMPLES | 6 EXPLAINED IN DETAIL

- Bell-LaPadula Model (*confidentiality*)
- Biba Model (*integrity*)
- Clark-Wilson Model (*integrity*)
- Noninterface Model (*multilevel security*)
- Brewer and Nash Model (*confidentiality*)
- Graham-Denning Model (*object manipulations*)
- Gougen Meseguer (*integrity*)
- Harrison-Ruzzo-Ullman Model (*integrity*)
- Take-Grant Model (*Safety*)
- Sutherland Model (*integrity*)
- Lipner Model (*confidentiality and integrity*)
- Lattice Model (*mathematical model*)

The above mentioned security models are hardly to be found in pure form in practice

BELL LAPADULA SECURITY MODEL EXPLANATION

- Framework for computer systems that store and process sensitive data
- State machine model (*first mathematical model of multilevel security policy*)
- Enforce confidentiality and define a secure state
- Matrix and security levels to identify if a subject can access an object

3 rules to ensure that data flows under the system policy

(1) The simple security rule

(No read up; A subject cannot read data inside of an object with higher security level)

(2) The *-property rule

(No write down; A subject cannot write data to an object at lower security level)

(3) The strong star property rule

(The subjects clearance and the objects classification must be the same for a subject that is able to read and write to an object)

BIBA SECURITY MODEL EXPLANATION

- Access control rules
- Enforce data integrity
- State machine as information flow model
- Use lattice integrity levels to make decisions

3 rules to ensure data integrity

(1) The simple integrity axiom

(No read down; A subject is not able to read data at a lower integrity level)

(2) The *-integrity axiom

(No write up; A subject is not able to write/modify an object at a higher integrity level)

(3) Invocation property

(A subject is not able to invoke an object at a higher integrity level; at runtime)

CLARK-WILSON MODEL

EXPLANATION

- Enforce integrity to protect data
- Well-formed transactions (*i.e., perform series of operations to transform data items from one consistent state to another consistent state*)
- Separation of duties principle
- Prevent unauthorized users making modifications
- Prevent authorized users making improper modifications
- Maintain internal and external consistency

3 Objectives to achieve integrity

- (1) Subjects can access objects only through authorized programs (access triple)
- (2) Separation of duties is enforced
- (3) Auditing is required

NONINTERFERENCE MODEL EXPLANATION

- Formal multilevel security model
- Activities (*e.g., commands*) at one security level should not affect or interfere with actions taking place for objects at different security level

2 attack types addressed

(1) Covert channel attack

(2) Interference attack (*e.g., derive knowledge about robust data from trivial data*)

BREWER AND NASH MODEL EXPLANATION

- Managing dynamically changing access controls in data flow
- Protect conflict of interests by user's access attempts in terms of confidentiality
- Also so-called „*Chinese wall*“ (*avoid insider transactions*)
- A subject can write to an object only if it cannot read another object in a different dataset

GRAHAM-DENNING MODEL

EXPLANATION

- Security model to manage objects and subjects (*i.e., create, delete, provide rights*)
- Defines a set of basic rights in terms of manipulation commands
- Commands are executed over an object

8 relevant protection rights

- How to securely create an object/subject (2)
- How to securely delete an object/subject (2)
- How to securely provide the read/grant/delete/transfer access right (4)

Agenda

Introduction

Security Models

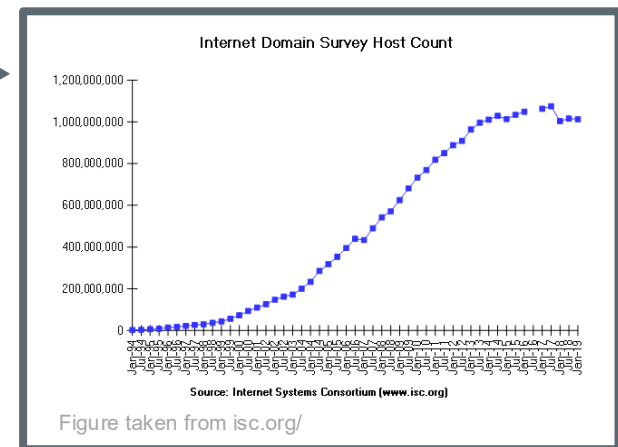
Network Security

Security Protocols

Summary

THE INTERNET IS GROWING NUMBERS OF HOST COUNTS

- A lot of systems are connected to the internet
- Connected systems via unprotected networks
- The www is fundamentally a client/server application running over the Internet and a number of TCP/IP intranet



Network components

Message, host, receiver, medium, protocol

***The www is vulnerable to attacks
on the Web servers that are accessible over the Internet***

THE MOTIVATION FOR NETWORK SECURITY

SELECTED EXAMPLE | WIRESHARK

- Open source packet analyzer
- Originally named „Ethereal“
- Cross-platform
- Similar to tcpdump – but with graphical frontend

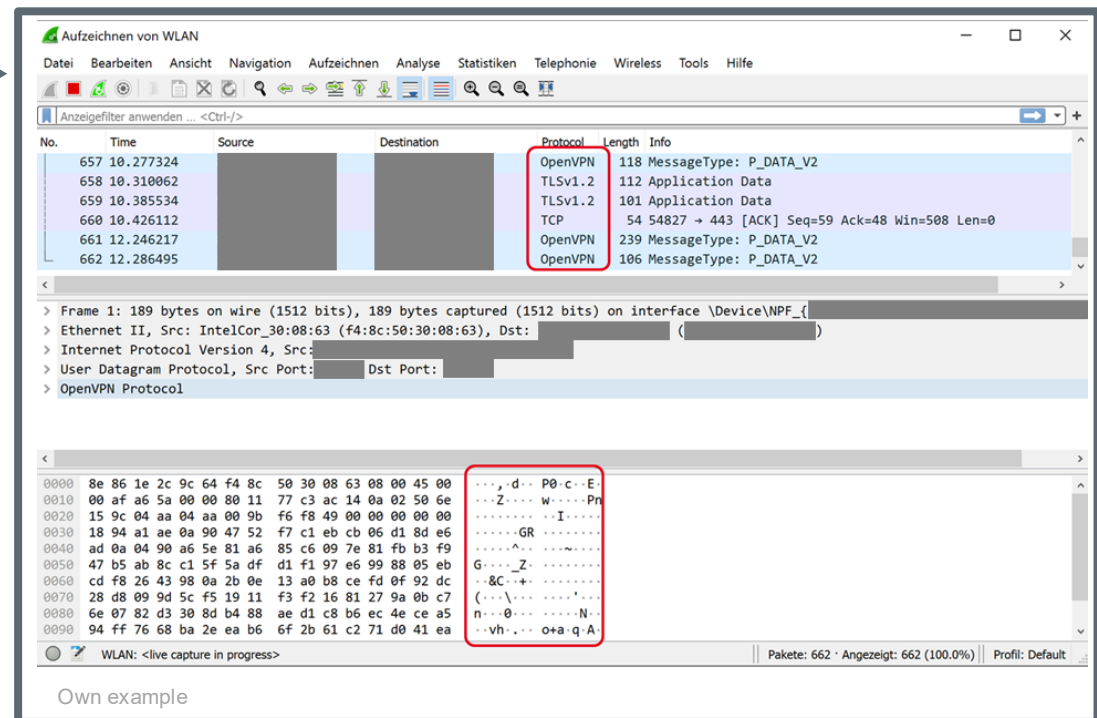
Wireshark as a motivation to network security

PRACTICAL EXAMPLE

WIRESHARK CAPTURE | WIFI | TLS 1.2 | VPN

Wireshark capture example

- WiFi Interface
- TLS 1.2 connection
- VPN activated
- Don't blame, but you can try yourself without VPN and/or without TLS*



GENERAL SITUATION ON THE WEB

THREATS, CONSEQUENCES AND COUNTERMEASURES

- Threats on the www vary
- CIA and Authenticity aspects covered

Countermeasures consolidated

- Cryptographic checksums (*e.g.*, SHA^1-512)
- Encryption (*e.g.*, AES^2 , ECC^3 , RSA^4)
- Web proxies
- WAF^5 (*e.g.*, *against DDoS*)
- Cryptographic techniques

	Threats	Consequences	Countermeasures
Integrity	- Modification of user data - Trojan horse browser - Modification of memory - Modification of message traffic in transit	- Loss of information - Compromise of machine - Vulnerability to all other threats	Cryptographic checksums
Confidentiality	- Eavesdropping on the net - Theft of info from server - Theft of data from client - Info about network configuration - Info about which client talks to server	- Loss of information - Loss of privacy	Encryption, Web proxies
Denial of Service	- Killing of user threads - Flooding machine with bogus requests - Filling up disk or memory - Isolating machine by DNS attacks	- Disruptive - Annoying - Prevent user from getting work done	Difficult to prevent
Authentication	- Impersonation of legitimate users - Data forgery	- Misrepresentation of user - Belief that false information is valid	Cryptographic techniques

Figure taken from (Stallings, 2011, p. 142)

¹ ISHA – Secure Hash Algorithm

² AES – Advanced Encryption Standard

³ ECC – Elliptic Curve Cryptography

⁴ RSA – Rivest Shamir Adleman

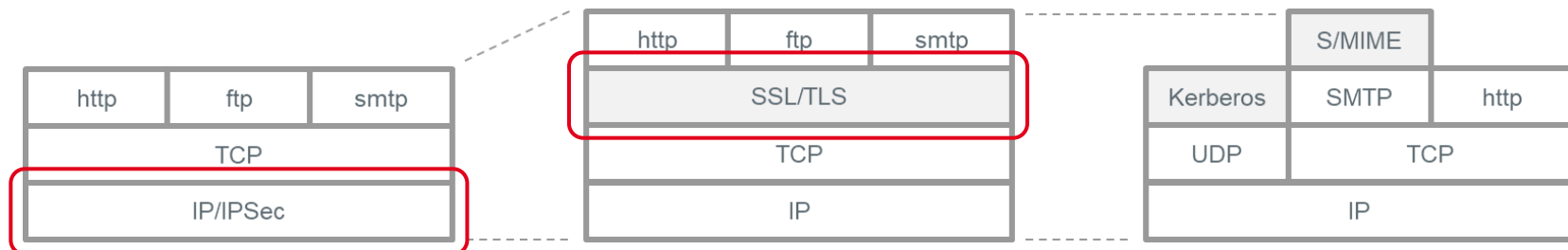
⁵ WAF – Web Application Firewall

TCP/IP PROTOCOL STACK SECURITY FACILITIES

- Several (*similar*) approaches possible to secure web connections
- Different location in TCP/IP protocol stack

3 general options to provide web security

- IPSec (*transparent to end-users and applications*)
- SSL/TLS above TCP (*embedded in packages or part of protocol suite*)
- Application-specific (*S/MIME and/or Kerberos*)



Own figure based on (Stallings, 2011, p. 142)

¹ S/MIME - Secure / Multipurpose Internet Mail Extensions

RELEVANT LAYERS AND PROTOCOL FEASIBLE ATTACK SURFACES

- Physical Layer
- IP¹
- ICMP²
- UDP³
- TCP⁴
- IGMP⁵
- Application Layer

¹ IP – Internet Protocol

² ICMP – Internet Control Message Protocol

³ UDP – User Datagram Protocol

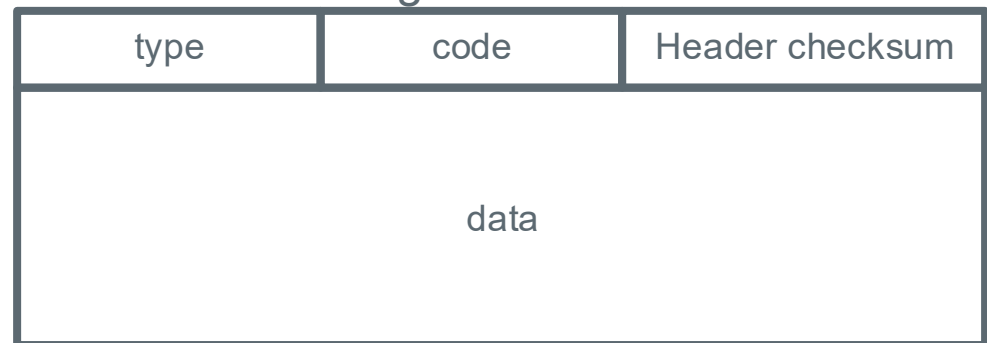
⁴ TCP – Transmission Control Protocol

⁵ IGMP – Internet Group Management Protocol

ICMP

PURPOSE AND GENERAL STRUCTURE

- Used to exchange control/error messages about the delivery of IP datagrams
(for IPv6: ICMPv6)
- ICMP messages are encapsulated inside of IP datagrams
- ICMP messages can be
 - Requests
 - Responses
 - Error messages



type : specifies class of ICMP message

code: specifies exact type of message

data: include header and first 8 bytes (*i.e., payload*) of original IP datagram

ICMP | RFC 792

SELECTED MESSAGE TYPES AND CODES

- 0 – Echo Reply
- 3 – Destination Unreachable *(used to inform a host that it is impossible to deliver traffic to a specific destination)*
 - 0 – Net Unreachable
 - 1 – Host Unreachable
 - 3 – Port Unreachable
 - 4 = fragmentation needed and DF set;
 - 5 = source route failed.
- 5 – Redirect *(used to inform hosts about better routes (gateways))*
- 8 – Echo request/reply
- 13 - Timestamp request/reply *(used to synchronize clocks)*
- [...]

ICMP ATTACKS

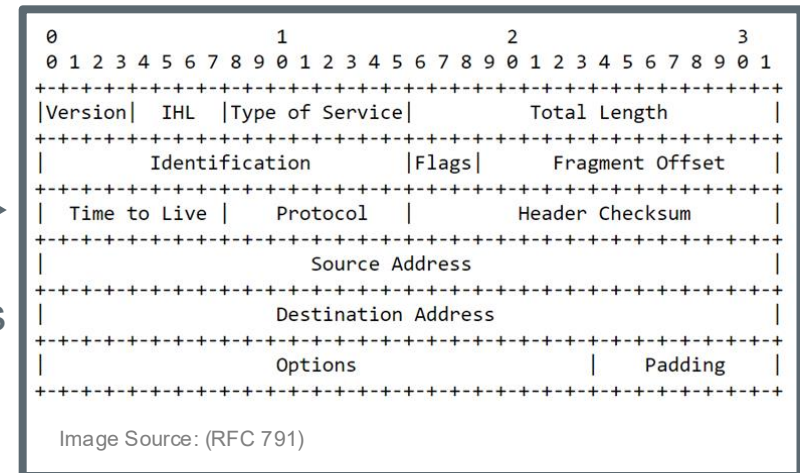
SELECTED EXAMPLES

- Destination Unreachable, TTL¹ exceeded
- ICMP Flood (*also „ping flood“ i.e., very simple DoS attack with ICMP echo requests*)
- Inverse Mapping (*ICMP Reply Message, Fehlermeldung*)
- Packet magnification ICMP echo request/ICMP echo reply (*„Smurf attack“*)
- Route Redirect (*or redirect bombs*)
- *„Ping of death“* too big packets, e.g., ping (*IP Fragmentation*)

¹ TTL – Time to Leave

INTERNET PROTOCOL V4 HEADER FORMAT STRUCTURE

- Introduced in 1981
- RFC¹ 791
- **Format**
- Packet-switched computer networks
- Each node on network unique IP address
- 32 bit addresses (*128 bit compared to IPv6*)



¹ RFC – Request for Comments

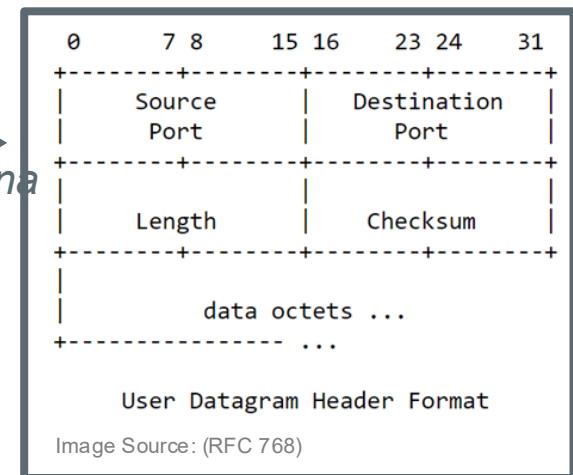
ATTACKS AGAINST IPV4

SELECTED EXAMPLES

- Address Spoofing
- Fragmentation
 - Ping of Death (*IP packet too big*)
 - Fragment Overlap Attack („*Teardrop*“)
 - Tiny Fragment Attack
- [...]

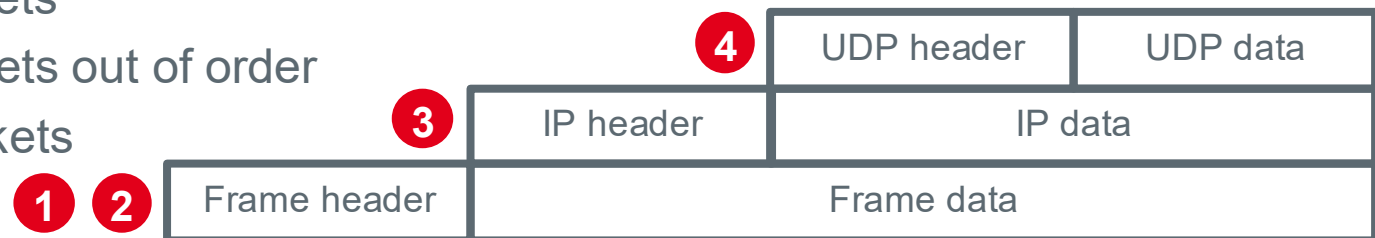
UDP STRUCTURE

- Transport layer
- Datagram header format
- Relies on IP but „unreliable“ (*because checksum optional*)
- UDP does not validate source IP addresses
- Connectionless
- Best-effort
- Datagram service delivery
- Not guaranteed: delivery, integrity, non-duplication, ordering
- UDP encapsulation



UDP ENCAPSULATION EXPLANATION

- Based on IP and unreliable
- Corrupted packets (*IP checksum only on headers*)
- Dropped packets
- Transmit packets out of order
- Duplicate packets



Unsolved UDP-problems

- Datagram may not arrive
- Datagram arrives corrupted (because optional checksum)
- Datagram arrives out of order
- Multiple copies of datagram arrive

ATTACKS AGAINST UDP

SELECTED EXAMPLES

DoS¹

- UDP packet storm (*e.g., chargen/echo*)
- (*Random*) UDP flood attack
- UDP-Based Amplification Attacks

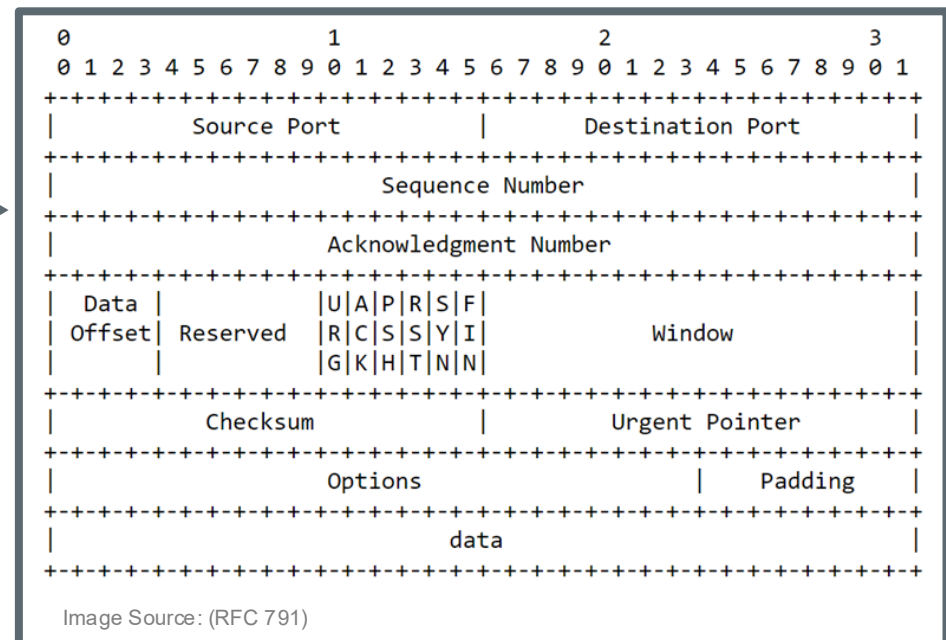
¹ DoS – Denial of Service

TCP STRUCTURE

- Relies on IP and is dependable
- Less efficient than UDP
- **Header format**
- Connection-oriented
- Stream delivery service
- TCP header format

Advantages of TCP

- no loss
- no duplication
- no transmission errors
- correct data ordering



TCP ATTACKS

SELECTED EXAMPLES

- Low-Rate TCP-targeted DoS¹ attack
- Send ACK before data are received
- Christmas Tree Packet (*Flags*)
- TCP Session Poisoning (z.B. *FIN*¹, *RST*²)
- Land-Attack (*Source Address/Port == Destination Address/Port*)
- TCP Sequence Number Prediction
- TCP Session Hijack (*Sniffing + Spoofing*)

¹ DoS – Denial of Service

² FIN – finish (*flag*)

³ RST – Reset

MAN-IN-THE-MIDDLE-ATTACK

AUTHENTICATION PROTOCOLS

- A malicious eavesdropper (*Eve*) is able to replay a fake message.
- Suggested solution: Timestamp

FIREWALLS FOR PROTECTION

LOCAL SYSTEMS OR NETWORKS OF SYSTEMS

- A barrier through which the ingress and egress traffic going must pass. A firewall security policy dictates which traffic is authorized to pass in both directions
- Designed to operate as a filter at the level of IP packets, or may operate at a higher protocol layer (*cf., blacklisting vs. whitelisting*)

Characteristics of firewalls

- (1) All inbound and outbound traffic must pass through the firewall Physically blocking all access to the local network except via the firewall. Various configurations are possible, as explained later in this chapter.
- (2) Only authorized traffic, as defined by the local security policy, allowed to pass.
- (3) The firewall itself is “immune” to penetration. This implies the use of a hardened system with a secured operating system (*dual-vendor system*).

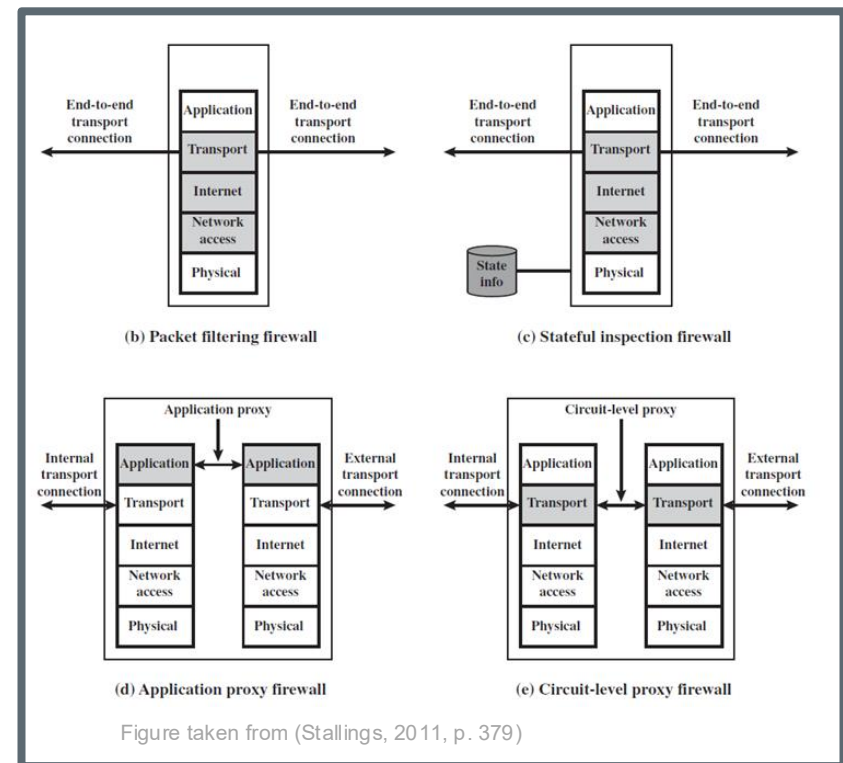
TYPES OF FIREWALLS SELECTED EXAMPLES

- Packet filtering firewall
- Stateful inspection firewall
- Application proxy firewall
- Circuit-level proxy firewall
- Web application firewall (WAF) detect and block malicious requests¹

Examples

- Netfilter
- Iptables

¹ Annotation: WAF are not given in the figure on this slide.



TYPES OF FIREWALLS

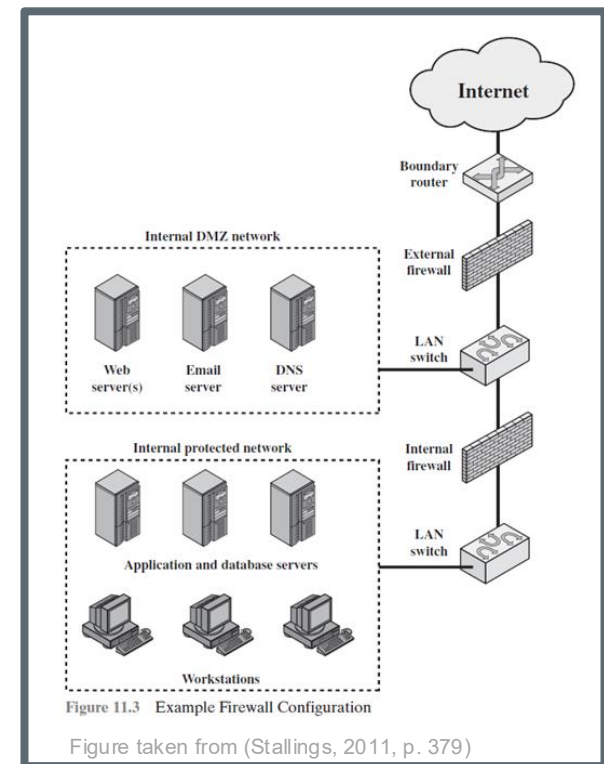
SELECTED EXAMPLES

- Packet filtering firewall
- Stateful inspection firewall
- Application proxy firewall
- Circuit-level proxy firewall
- Web application firewall (WAF) detect and block malicious requests¹

Examples

- Netfilter
- Iptables

¹ Annotation: WAF are not given in the figure on this slide.



PACKET FILTERING FIREWALLS

EXTRACTED DETAILS

Packet filtering firewalls usually permit or deny inbound or outbound network traffic based

- Source and destination IP addresses
- Protocol (*TCP, UDP, or ICMP*)
- Source and destination TCP or UDP port addresses
- Flags in the TCP header – ACK, CLOSE, and SYNC
- IP fragmentation flag
- Direction of the packet – inbound or outbound
- Physical interface

INTRUSION DETECTION AND INTRUSION PREVENTION

IDS AND IPS

Objective: avoid to maliciously entering our systems by attacker and detect anomalies

- True positives (*True attack alarms generated*)
- True negatives (*No alarms, no attacks*)
- False positives (*No attack, alarms generated*)
- False negatives (*No alarm, true attack*)

2 types of IDS

- **Host-based IDS** Protects the end system or the network resources
- **Network-based IDS** Monitors network traffic for attacks. A Network IDS is deployed on the network near a firewall, on the DMZ or even inside the trusted internal network

THE DIFFERENCES BETWEEN IDS AND IPS

BRIEF OVERVIEW

Intrusion Detection System (IDS)

- Passively monitors network behavior and “*detects*” attacks
- Supports both Network and Host level detection
- Passive monitoring, does not sit in the data path
- Supports both network and host level detection
- Key measure is detection accuracy
- NIDS: ISS, Cisco, Enterasys, Symantec
- HIDS: ISS, Symantec, Enterasys

Intrusion Prevention System (IPS)

- Actively analyzes network behavior and “prevents” attacks in real-time
- Supports both network and host level detection
- Active monitoring, deployed in-line mode
- Key measure is lesser number of false positives
- NIPS: McAfee Intrushield, NetScreen, Tippingpoint.
- HIPS: Cisco, McAfee (Entercept). Snort an open source Network IDS/IPS developed by Sourcefire

WIFI SECURITY

SELECTED ATTACKS AND GENERAL OBSERVATIONS

- Unsecure Networks
- Attacks have access to medium
- Used in unsecure areas (airports, hotels)

Selected attacks

- Sniffing
- Spoofing
- Denial of Service

WIFI SECURITY

HOW TO SECURE A WIRELESS NETWORK

Apply layered security principle to select adequate protection mechanisms

- (1) Encrypt WIFI-connection with state of the art encryption mechanisms
(e.g., WPA2 CCMP or WPA3; example: current Fritz!OS 07.21 WPA2 + WPA3 transition mode)
- (2) Use secure passwords (*attention: time-based passwords are no longer adequate*)
- (3) Change WiFi SSID
- (4) Disable remote access
- (5) Update firmware, regularly to patch vulnerabilities
- (6) Disable WPS (*Push button vs. WPS PIN*)
- (7) Protect, disable or isolate guest WiFi
- (8) Allocate static IP address to connected devices and disable dhcp
- (9) Activate MAC filter
- (10) Restrict access to WiFi on a time schedule if not needed

Agenda

Introduction

Security Models

Network Security

Security Protocols

Summary

NETWORK COMMUNICATION

SELECTED ATTACKS

When communicating via a network, attackers can read, change and pretend information or interrupt the communication. Since the Internet is a network of relatively autonomous networks rather than a single network, there are many potential attackers. In practice it is possible to listen to and manipulate transmitted data at endpoints and intermediate stations

Relevant attacks

- MAC Address-Spoofing
- ARP¹-Spoofing
- IP-Spoofing TCP Sequence Number Attack
- DNS-Spoofing

¹ ARP – Address Resolution Protocol

TLS

SOME FACTS

- TLS is the successor of SSL (*Secure Sockets Layer*)
- Latest version: TLS 1.3 (*August 2018*), very often applied in practice: TLS 1.2
- Above TCP in network stack and https¹ = http over TLS
- Default by Google Chrome and Firefox (*where applicable*)

TLS is applicable for

- Authentication (einseitig oder beidseitig)
- Encryption of the communication on transport layer
- Encryption between 2 components on OSI² layer 4
- Confidentiality for end-to-end via a number of nodes – higher layer required

¹ https – Hypertext Transfer Protocol Secure

² OSI – Open Systems Interconnection model

TLS

QUICK OVERVIEW

The Internet standard version is called TLS to provide security services between TCP and applications that use TCP.

- SSL/TLS includes protocol mechanisms to enable two TCP users to determine the security mechanisms and services they will use
- SSL/TLS provides confidentiality (*symmetric encryption*) and message integrity (*message authentication code - MAC*).
- https is a combination of both http and SSL/TLS to implement secure communicationsa between a web browser and a web server (*e.g., online platform*)
- ssh provides secure remote logon and other secure client/server facilities

TLS 1.2 | SELECTED EXAMPLES OF CIPHER SUITES

WIDELY IN USE | ALSO E.G. IN TRANSITION MODE FOR WIFI

```
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA2561,2,3,4,5  
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA2566  
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384  
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA2567  
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256  
TLS_RSA_WITH_AES_256_GCM_SHA384
```

¹ ECDHE – Elliptic Curve Diffie Hellman

² ECDSA – Elliptic Curve Digital Signature Algorithm

³ AES – Advanced Encryption Standard

⁴ CBC – Cipher Block Chaining

⁵ SHA – Secure Hash Algorithm

⁶ GCM – Galois Counter Mode

⁷ RSA – Rivest Shamir Adleman

TLS FOR NOSQL SYSTEM MONGODB

SELECTED PRACTICAL EXAMPLE

Important for MongoDB because extensively used system connected to internet

TLS encryption mechanism encrypts the communication

- Between the primary daemon process "*mongod*" and the mongo shell "*mongos*"
- Between MongoDB and all connected applications
- Protect replica sets with a number of nodes
- Data protection in-transfer via TLS (*SSL disabled*) PFS via DHE^{1,2} and ECDHE³
- No data alteration by MITM⁴ attacker possible (*practically*)
- No attacker can access the data that is transferred via the connection between the application/ the client and the database

¹ DHE – Diffie Hellman Ephemeral

² Annotation: A cryptographic key is called ephemeral if it is generated for each execution of a key agreement/establishment process.

³ ECDHE – Elliptic Curve Diffie Hellman

⁴ MITM – Man in the middle

TLS 1.3

SELECTED MAJOR IMPROVEMENTS

- RSA key exchange and RSA key encryption removed
- Ephemeral Diffie-Hellman as the only remaining key exchange mechanism
- Perfect forward secrecy (*PFS – not possible to derive long-time key from session key*)
- Preferred AEAD¹ cipher suites confidentiality, integrity, authenticity (e.g., *ssh*² for remote access)
- MD5³ and SHA⁴-224 not allowed
- Eliminated vulnerabilities BEAST, CRIME, downgrade attack
- Performance optimization (*quicker handshake*)

¹ AEAD – Authenticated Encryption with Associated Data

² ssh – Secure Shell

³ MD5 – Message Digest 5

⁴ SHA – Secure Hash Algorithm

⁵ BEAST – Browser Exploit Against SSL/TLS

⁶ CRIME – Compression Ratio Info-leak Made Easy

5 TLS 1.3¹ AEAD CIPHER SUITES FOR OPEN SSL PARTICULAR EXAMPLES

- TLS_AES¹_256_GCM²_SHA384
- TLS_CHACHA20³_POLY1305⁵_SHA256
- TLS_AES_128_GCM_SHA256
- TLS_AES_128_CCM_8_SHA256
- TLS_AES_128_CCM_SHA256



The diagram illustrates the components of the TLS cipher suite TLS_AES_256_GCM_SHA384_P384. It is structured as follows: TLS (Transport Layer Security) is the base protocol. ECDHE (Elliptic Curve Diffie-Hellman Ephemeral) is the Key Exchange algorithm. ECDSA (Elliptic Curve Digital Signature Algorithm) is the Digital Signature algorithm. WITH is a connector. AES_256_GCM (Advanced Encryption Standard 256-bit in Galois Counter Mode) is the Bulk Encryption algorithm. SHA384 is the Message Authentication Code (MAC) algorithm. P384 is the Elliptic Curve used for key exchange and signatures.

Own figure

TLS 1.3 (i.e., the TLS 1.2 Successor) was Published as RFC 8446⁶ in 08-2018

¹ AES – Advanced Encryption Standard

² GCM – Galois Counter Mode

³ CHACHA20 – A 256 bit 20 round Stream cipher and a variant of Salsa20 where ChaCha is the family of stream ciphers

⁴ BEAST – Browser Exploit Against SSL/TLS

⁵ CRIME – Compression Ratio Info-leak Made Easy

⁶ cf. IETF, RFC 8446, The Transport Layer Security (TLS) Protocol Version 1.3, August 2018

IPSEC

GENERAL OVERVIEW

A set of protocol suites that provides cryptographically designed security services for IPv4 and IPv6 to achieve confidentiality and authentication at IP (OSI) layer (3).

- Site-to-site VPN-Tunnels (*e.g., via WAN oder Internet*)
- Security architecture for IPv4 (*voluntary*) and IPv6 (*mandatory*)

IPSec includes

- Security Associations (SA) - applicable cryptographic algorithms
- Authentication Header (AH) – derive MAC that includes payload and IP-header
- Encapsulating Security Payload (ESP) – ESP header and trailer
- Internet Security Association Key Management Protocol (ISAKMP)
- Internet Key Exchange (IKE) – Initial key negotiation
- Cryptographic algorithms for authentication and encryption

IPSEC

RELEVANT BUILDING BLOCKS

- RFC 4301: IP security architecture.
- RFC 4302: IP Authentication Header (AH),
- RFC 4303: IP Encapsulating Security Payload (ESP)
- RFC 4304: Extended Sequence Number (ESN)
Addendum, RFC 4305: Cryptographic algorithm implementation requirements for ESP and AH.
- RFC 4307: Cryptographic algorithms used with IKEv2.
- RFC 4308: Crypto suites for IPsec, IKE, and IKEv2.
- RFC 4309: The use of AES in CBC-MAC mode with IPsec ESP.
- RFC 4312: The use of the Camellia cipher algorithm in IPsec.
- RFC 4359: The Use of RSA/SHA-1 Signatures within Encapsulating Security Payload (ESP) and Authentication Header (AH).
- RFC 4434: Describes AES-XCBC-PRF-128, a pseudo-random function derived from the AES for use with IKE.
- RFC 5996: The Internet Key Exchange (IKE) protocol, version 2
- RFC 2403: Describes use of the HMAC with MD5 algorithm
- RFC 2405: Describes use of DES-CBC
- RFC 2407 (application of ISAKMP to IPsec),
- RFC 2408 (ISAKMP, a framework for key management and security associations)
- RFC 2409
- RFC 2412: Describes OAKLEY, a key determination and distribution protocol.
- RFC 2451: Describes use of Cipher Block Chaining (CBC) mode cipher algorithms with ESP.
- RFCs 2522 and 2523: Description of Photuris, a session-key management protocol for IPsec.

Agenda

Introduction

Security Models

Network Security

Security Protocols

Summary

SUMMARY

COVERED TOPICS

- **Demonstrated** selected security protocols
- **Discussed** different types of **firewalls**
- **Clarified** basic **terminology** of network security aspects
- **Explored particular attacks against network infrastructures**
- **Presented** the basic **security models**
- **Identified Cryptographic algorithms**, corresponding **parameters** and **strengths of mechanisms** that are applicable for certifiable products
- **Extracted** concrete **examples** of **certified cryptographic products**
- **Discussed experiences** from conducted projects

